REPORT

INCIDENT RESPONSE PLAN

---

1. EXECUTIVE SUMMARY

Phishing remains a significant cybersecurity threat to organisations because it exploits human behaviour to obtain sensitive information, compromise user accounts, distribute malicious software and facilitate financial fraud. For organisations operating in the financial services sector, a successful phishing incident may expose confidential information, compromise business communications, disrupt operations or result in financial losses.

This project addresses the need for a practical and coordinated approach to identifying suspicious emails and responding to phishing-related security incidents at JS Capital Limited, an investment banking company involved in equities and fixed-income trading on the Nairobi Securities Exchange.

The project combines two complementary components:

1. **A Python-based Phishing Email Checker:** A defensive tool designed to examine email content for defined suspicious indicators, explain the indicators identified and provide a cautious risk summary to support initial assessment.
2. **A Phishing Incident Response Plan (IRP):** A structured operational document setting out how employees and designated responders should report, assess, contain, eradicate and recover from suspected or confirmed phishing incidents.

The IRP has been developed around JS Capital Limited's stated operating environment, comprising 32 employees, Microsoft 365, employee laptops and mobile devices, internet access, endpoint protection and multi-factor authentication (MFA). It also takes account of the organisation's small IT department and the need for clear escalation and management oversight.

The principal outcome is an integrated defensive response framework that connects initial phishing identification with incident reporting, investigation, escalation, containment, recovery and post-incident learning. The project is intended as a practical security-support solution rather than a replacement for human judgement, technical investigation or a wider organisational incident response capability. Further testing, validation and technical integration are required before the solution can be treated as production-ready.

2. PROBLEM STATEMENT

Phishing emails are designed to deceive recipients into taking actions that may compromise organisational security. These actions include clicking malicious links, opening suspicious attachments, disclosing login credentials, approving unexpected MFA requests, sharing confidential information or acting on fraudulent payment instructions.

For JS Capital Limited, these threats are particularly relevant because employees use corporate email, laptops and mobile devices to conduct business and communicate with internal and external parties.

A phishing incident may create several risks, including:

- Unauthorised access to Microsoft 365 accounts and corporate email.
- Compromise of employee credentials and authentication mechanisms.
- Unauthorised access to confidential business or client information.
- Business email compromise and fraudulent payment instructions.

- Malware infection or compromise of employee devices.
- Financial loss, operational disruption and reputational damage.
- Potential personal data breaches and related legal or regulatory obligations.

The problem addressed by this project is therefore twofold. First, employees need a practical way to identify and understand suspicious email indicators before interacting with potentially malicious content. Second, the organisation needs a documented and repeatable procedure for responding when a suspicious email is reported or a phishing incident is suspected or confirmed. Without a coordinated process, employees may fail to report suspicious messages promptly, responders may overlook important evidence, incidents may be escalated too late, and containment or recovery actions may be inconsistent.

Project problem statement: JS Capital Limited requires a practical phishing identification and incident response framework that supports early detection, timely reporting, consistent investigation and coordinated response to phishing-related security incidents.

3. PROJECT OBJECTIVES

The project seeks to:

1. Develop a Python-based phishing email checker that identifies defined suspicious indicators in email content.
2. Provide users with explanations of detected indicators and a cautious risk summary.
3. Establish a clear process for employees to report suspected phishing incidents.
4. Develop a structured Incident Response Plan covering the principal stages of phishing incident management.
5. Define incident severity levels, escalation requirements and responsibilities.
6. Establish procedures for evidence preservation, containment, eradication, recovery and post-incident review.
7. Incorporate legal, confidentiality and data protection considerations into incident response.
8. Provide practical templates that support consistent reporting, investigation and documentation.

4. INTENDED USERS AND PROJECT SCOPE

4.1 Intended users

The proposed solution is intended for:

- **Employees:** To check suspicious emails and report suspected phishing incidents.
- **IT Administrator:** To receive reports, conduct initial technical investigations and implement authorised technical response measures.
- **Incident Response Lead (IRL):** To coordinate incident response, assess severity, maintain incident records and oversee closure.
- **Management:** To oversee significant incidents, approve material business decisions and provide resources.
- **Legal/Data Protection Adviser:** To advise on confidentiality, personal data breaches, contractual obligations and applicable notification requirements.
- **HR/Communications:** To assist with employee coordination and internal communications where necessary.

4.2 Scope

The project focuses on phishing-related threats, including:

- Deceptive emails impersonating employees, suppliers, customers, banks or service providers.
- Credential-harvesting links and fake login pages.
- Suspicious email attachments.
- Business email compromise.
- Unauthorised mailbox access, forwarding rules and payment diversion.
- Phishing campaigns affecting multiple employees.

The project is designed around the stated JS Capital Limited environment: Microsoft 365, employee laptops, employee mobile devices, internet access, endpoint protection and MFA.

5. PROPOSED SOLUTION AND PROJECT APPROACH

The project adopts a layered defensive approach in which phishing identification is connected to a documented incident response process.

5.1 Component One: Python-based Phishing Email Checker

The Phishing Email Checker is intended to provide an initial assessment of suspicious email content. It is intended to explain which indicators have been identified and produce a cautious risk summary. The checker is a triage aid. Its output should not be treated as conclusive proof that an email is malicious or safe. Contextual review and further investigation by authorised personnel remain necessary.

5.2 Component Two: Phishing Incident Response Plan

The IRP translates the initial identification of suspicious emails into a structured organisational response.

The plan establishes the following six phases:

Phase	Main activities
1. Preparation	Maintain reporting channels, contact lists, access controls, evidence storage and staff guidance.
2. Identification and initial assessment	Log reports, preserve original emails, establish what happened, review available logs and assign provisional severity.
3. Containment	Quarantine malicious messages, reset credentials, revoke sessions, isolate affected devices where appropriate and limit further harm.
4. Eradication	Remove malicious files, unauthorised mailbox rules, attacker persistence and other identified causes of compromise.
5. Recovery	Restore affected accounts, devices and services, verify security controls and monitor for renewed compromise.
6. Post-incident review	Reconstruct the incident, identify root causes, evaluate the response and assign corrective actions.

The IRP also defines responsibilities for employees, IT, the Incident Response Lead, management, HR/Communications and legal/data protection advisers.

5.3 Incident severity and escalation

The IRP establishes four severity levels:

- **Low:** A suspicious message was received, but there was no interaction or evidence of compromise.
- **Medium:** A link was clicked or attachment opened, but there is no known disclosure or confirmed compromise.
- **High:** Credentials or MFA information may have been disclosed, suspicious account activity exists, malware may have executed, or sensitive information may be exposed.
- **Critical:** Multiple accounts or systems are compromised, material data exfiltration or successful fraudulent payment has occurred, or there is major disruption or serious harm.

The severity assigned is based on the actual or reasonably suspected impact, not merely the Phishing Email Checker score. This distinction is important because a suspicious email may have a high indicator score without resulting in compromise, while a seemingly ordinary message may lead to serious consequences if credentials are disclosed.

5.4 Operational documentation and templates

To make the IRP usable in practice, five operational templates were developed:

1. **Phishing Incident Reporting Form:** Captures the reporter's details, affected mailbox, email information and actions taken by the recipient.
2. **Incident Investigation Checklist:** Guides IT through evidence preservation, user interviews, log reviews and initial assessment.
3. **Severity and Escalation Matrix:** Supports consistent severity classification and notification decisions.
4. **Incident Register:** Provides a central record of reported incidents, severity, status, ownership and closure.
5. **Post-Incident Review Form:** Records lessons learned, root causes, impact and corrective actions.

These templates are intended to make incident response more consistent, traceable and auditable.

6. METHODOLOGY

The project followed a practical, problem-oriented approach.

6.1 Identification of the security problem

The project began by identifying phishing as a relevant threat to organisations relying on corporate email and digital communication. The organisational context was defined using the JS Capital Limited profile set out in the IRP.

6.2 Definition of scope and requirements

The project was limited to phishing identification and response. The main requirements were:

- A practical method of identifying suspicious email indicators.
- A clear employee reporting route.
- Defined technical and management responsibilities.

- A repeatable incident response procedure.
- Severity classification and escalation.
- Evidence preservation and incident documentation.
- Legal and data protection assessment where relevant.

6.3 Development of the defensive outputs

The project outputs were organised into two complementary components: the phishing email checker and the Incident Response Plan. The IRP was developed to address the operational steps that follow an employee's identification or reporting of a suspicious email.

6.4 Incorporation of security and governance considerations

The IRP incorporates several important principles:

- Prompt reporting and escalation.
- Preservation of original emails and relevant technical evidence.
- Restricted access to incident records.
- Documentation of decisions, actions, timestamps and responsible persons.
- Proportionate containment and recovery measures.
- Management oversight of significant incidents.
- Legal and data protection assessment where personal information may have been compromised.

6.5 Review and validation approach

The IRP includes three tabletop exercise scenarios:

1. An employee receives a suspicious supplier invoice email but does not interact with it.
2. An employee clicks a link but does not disclose credentials.
3. An employee enters a work password and approves an unexpected MFA request.

These scenarios provide a basis for testing whether the reporting route, escalation process, severity matrix and response procedures are understandable and operationally workable. However, the existence of these scenarios in the IRP should not be presented as proof that the exercises have already been conducted. Their execution and results should be documented separately.

7. PROJECT RESULTS AND DELIVERABLES

7.1 Completed artefact: Incident Response Plan

The principal documented output is the Phishing Incident Response Plan for JS Capital Limited. The IRP provides a structured framework for managing suspected and confirmed phishing incidents and includes:

- Purpose, objectives and organisational profile.
- Scope and response principles.
- Definitions and responsibilities.
- Employee reporting and incident activation procedures.
- Severity classification and escalation requirements.
- Six operational response phases.
- Evidence preservation and incident record requirements.
- Internal and external communications procedures.
- Legal and data protection assessment.

- Incident closure criteria.
- Training, testing and maintenance requirements.
- Five operational response templates.

7.2 Organisational response capability

The IRP establishes a defined reporting route through the Incident Reporting Tab on the Phishing Email Checker. It also provides an emergency escalation route to the IT department for suspected account compromise, financial fraud or credential disclosure. This creates a clearer relationship between the employee's initial identification of a suspicious message and the organisation's formal incident response process.

7.3 Improved incident accountability

The assignment of responsibilities and introduction of an incident register create a basis for recording who reported an incident, who investigated it, what decisions were made, what actions were taken and when the incident was closed.

7.4 Integration of legal and data protection considerations

The IRP recognises that phishing incidents may involve confidentiality, personal data, contractual and regulatory concerns. It requires potential personal data breaches to be referred for appropriate assessment and avoids assuming that every suspicious email automatically constitutes a reportable personal data breach.

8. FINDINGS AND SECURITY CONSIDERATIONS

The project identifies several important security and operational considerations.

Finding 1: Need for a defined phishing reporting process

- **Affected area:** Employee email security and incident reporting.
- **Observation:** Without a clear reporting route, employees may delay reporting suspicious messages or attempt to investigate them independently.
- **Potential impact:** Delayed reporting may increase the opportunity for credential compromise, unauthorised access, malware execution or financial fraud.
- **Recommendation:** Use the Incident Reporting Tab and maintain an emergency reporting channel for suspected account compromise, financial fraud or credential disclosure.

Finding 2: Risk of treating automated checker results as conclusive

- **Affected area:** Phishing Email Checker and incident triage.
- **Observation:** An automated checker can identify defined suspicious indicators, but its output cannot independently establish whether an email is malicious or whether an account has been compromised.
- **Potential impact:** Overreliance on automated scores may result in false positives, false negatives or inappropriate incident severity decisions.
- **Recommendation:** Treat the checker as a triage aid. Require contextual assessment by authorised personnel and base incident severity on actual or reasonably suspected impact.

Finding 3: Need for timely containment of compromised accounts

- **Affected area:** Microsoft 365 accounts and employee authentication.
- **Observation:** Disclosure of credentials or approval of an unexpected MFA request may create an opportunity for unauthorised account access.

- **Potential impact:** An attacker may access email, create forwarding rules, send fraudulent messages or obtain confidential information.
- **Recommendation:** Immediately escalate suspected account compromise, reset affected credentials, revoke active sessions where supported, review MFA methods and inspect mailbox rules and account activity.

Finding 4: Need for evidence preservation and accountability

- **Affected area:** Incident investigation and records management.
- **Observation:** Screenshots alone may not preserve all relevant technical information. The IRP therefore requires preservation of original emails, headers, logs, user statements and response records.
- **Potential impact:** Inadequate evidence may make it difficult to reconstruct events, assess impact, support legal advice or demonstrate how the organisation responded.
- **Recommendation:** Maintain restricted incident records, preserve evidence in original format where possible and record evidence access, decisions, timestamps and responsible persons.

Finding 5: Legal and data protection implications

- **Affected area:** Confidentiality, personal data and regulatory compliance.
- **Observation:** A phishing incident may expose personal data, client information or confidential business information.
- **Potential impact:** The organisation may face legal, contractual, regulatory, financial or reputational consequences depending on the facts and applicable obligations.
- **Recommendation:** Refer potential personal data breaches promptly to management and the relevant legal or data protection adviser for a documented assessment of the nature of the information, affected individuals, likely consequences and applicable notification obligations.

9. LIMITATIONS

The project has a defined scope and should not be represented as a complete enterprise-grade security solution.

The principal limitations are:

9.1 Detection limitations

The Phishing Email Checker relies on defined suspicious indicators. It may not identify every phishing email, particularly sophisticated messages that contain no obvious warning signs. It may also flag legitimate messages that use urgent language, contain external links or request information for legitimate business purposes.

9.2 Dependence on human judgement

The checker cannot independently confirm whether an email is malicious, whether a user account has been compromised or whether confidential information has been accessed. Human review and technical investigation remain necessary.

9.3 Limited technical validation evidence

The attached IRP does not include the Python source code, a complete set of test cases, test results, screenshots or performance measurements for the checker. Consequently, the project's detection accuracy, reliability and technical performance cannot yet be quantified from the available artefacts.

9.4 Dependence on available organisational resources

The IRP is designed around a small IT department. Effective implementation will depend on the availability of personnel, appropriate Microsoft 365 administrative permissions, endpoint protection capabilities and access to relevant logs.

9.5 No demonstrated production integration

The IRP refers to an Incident Reporting Tab on the Phishing Email Checker. However, the attached document does not demonstrate a completed technical integration, automated incident register or functioning notification workflow. These features should be demonstrated and tested before being described as operational.

9.6 Legal and regulatory assessment remains fact-specific

The IRP provides a process for legal and data protection assessment but does not prescribe a universal notification deadline. The applicable legal requirements must be verified against the facts and current law at the time of an incident.

10. RECOMMENDATIONS AND NEXT STEPS

The following activities are recommended to improve the project's technical maturity and operational readiness.

Proposed IRP tabletop testing

The three scenarios already included in the IRP should be conducted with the relevant participants.

The exercise should establish whether:

- Employees know how to report suspicious messages.
- The IT Administrator knows what information to collect.
- The Incident Response Lead can assign an appropriate severity level.
- The organisation can identify and execute appropriate containment actions.
- Evidence is preserved and incident decisions are recorded.
- Legal and data protection issues are recognised and escalated.
- Corrective actions are assigned to responsible persons.

The outcome should be documented using the Post-Incident Review Form.

11. CONCLUSION

The Phishing Email Checker and Incident Response Framework project addresses an important defensive cybersecurity problem: the need to identify suspicious emails and respond to phishing-related incidents in a structured and timely manner. The project combines an automated initial assessment concept with an operational Incident Response Plan tailored to JS Capital Limited's stated environment.

The IRP establishes clear reporting procedures, incident severity levels, response responsibilities, six operational response phases, evidence-handling requirements and practical documentation templates.Importantly, the project recognises that effective phishing defence requires more than identifying suspicious emails. It requires employee awareness, timely escalation, technical investigation, evidence preservation, management oversight and appropriate legal and data protection assessment.